AI-Driven Augmented Knowledge Base to Support Cyber Security Practitioners

Team: **OS1B**

Member: Yifan Gu
Cong Deng
Sheng Wang
Tianhua Zhang
Xin Wei

Agenda

- Project Overview
- Demo Scenarios
- System Design
- Conclusion & Reflection

Project Overview

01

1.1 Project Background

COMPANIES

Many companies have suffered substantial financial losses due to cyber security vulnerabilities.

2022 Optus Data Breach

Cause: An unauthenticated API endpoint exposed personal information of 10 million customers.

Our database

Does Keycloak support basic Authentication?

Asked 5 years, 9 months ago Modified 1 year, 7 months ago Viewed 22k times

11

Does Keycloak support basic Authentication (Authorization header that contains the word Basic word followed by a space and a base64-encoded string username:password) and if so how I can configure realm and client settings for it ? I want to secure my rest api with Keycloak and support also basic Authentication as an option.

Spring with JWT auth, get current user

Asked 6 years, 11 months ago Modified 1 year, 5 months ago Viewed 41k times

I have Spring Boot REST application which uses JWT tokens for authorization. I want to get current logged user in controllers using `@AuthenticationPrincipal` annotation. But it always returns `null` if i return custom model from `loadUserByUsername` and auth stop working. My model implements `UserDetails`.

I tried to extend the `org.springframework.security.core.userdetails.User` but i get rid errors from **JWTAuthenticationFilter** that default constructor not exists (`ApplicationUser creds = new ObjectMapper().readValue(req.getInputStream(), ApplicationUser.class);`)

Whats wrong?

1.2 Project Goals

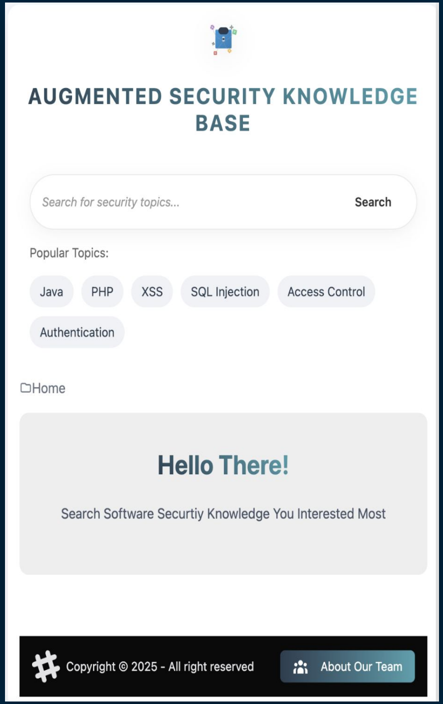
- **DATASET** 385 manually verified security-related posts from Stack Overflow, covering 50 programming languages.
- **GOAL** An AI-driven Augmented Knowledge Base to support developers learning security questions

Demo Scenarios

02

2. Demo Scenarios

OUR PRODUCT



INPUT

Keywords or questions about security issues

OUTPUT

Category, challenges, skills required, solutions, Similarity, Sentiments, and related Stack Overflow posts

2. Demo Scenarios

Use Case 1

Scenario: Stack Overflow Accepted Answer Missing

User Input : Java Security

Related Overstack Questions : Top3 related Questions

Related Stack Overflow Questions

go web servic secur java	View
java troubl check password string valid	View
random class java securerandom class	View

Comparison: Knowledge Base Answer & Accepted Answer Comparison

LLM Answer	Summary: Java → Random vs. SecureRandom → Performance and Purpose - The Random class is generally faster than the SecureRandom class due to its algorithm, which is optimized for performance. - However, the main reason to use the SecureRandom class is its cryptographic strength, ensuring unpredictable numbers suitable for security-critical applications. - While both classes can generate pseudorandom integers, the SecureRandom class provides a higher level of randomness and predictability.
Accepted Answers	

2. Demo Scenarios

Use Case 2

Scenario: Stack Overflow Accepted Answer Too Ambiguous

User Input : Java Security

Related Overstack Questions : Top3 related Questions

Related Stack Overflow Questions	go web servic secur java	View
	java troubl check password string valid	View
	random class java securerandom class	View

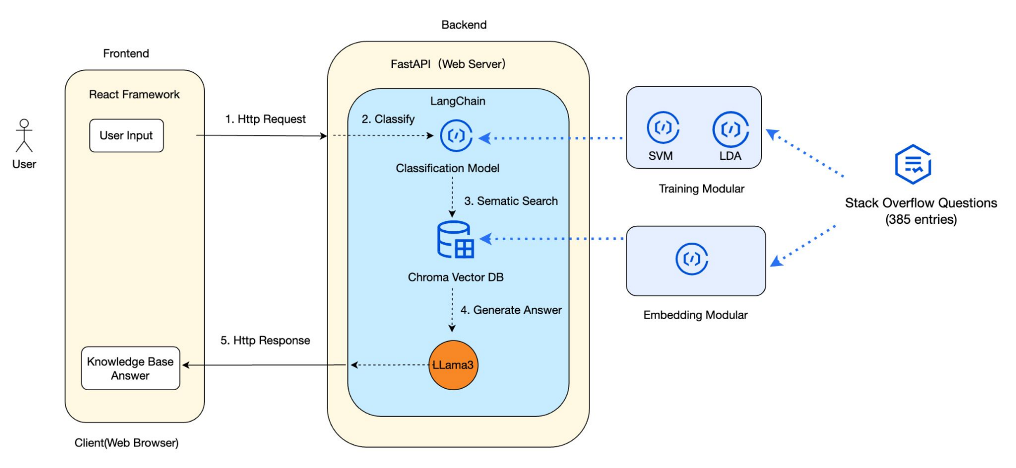
Comparison: Knowledge Base Answer & Accepted Answer Comparison

LLM Answer	Here's my answer: Summary: Java → JBoss EAP → WS-Security - Use WS-Security to implement authentication and encryption for your web service. - Implement token-based authentication using a token service (e.g., STS) to manage client credentials. - Leverage the JBoss EAP built-in support for Web Services Interoperability (WS-I) to ensure compatibility with other services. Note: The provided links (http://www.xml.com/pub/a/2003/12/17/dive.html and http://www.sixapart.com/developers/atom/protocol/atom_authentication.html) are relevant reading materials on web service security.
Accepted Answers	For web services security in JBoss, I would start by reading 8.4 WS-Security of the JBossWS User Guide.

System Design 03

3. System Design

3.1 Architecture Design Overview



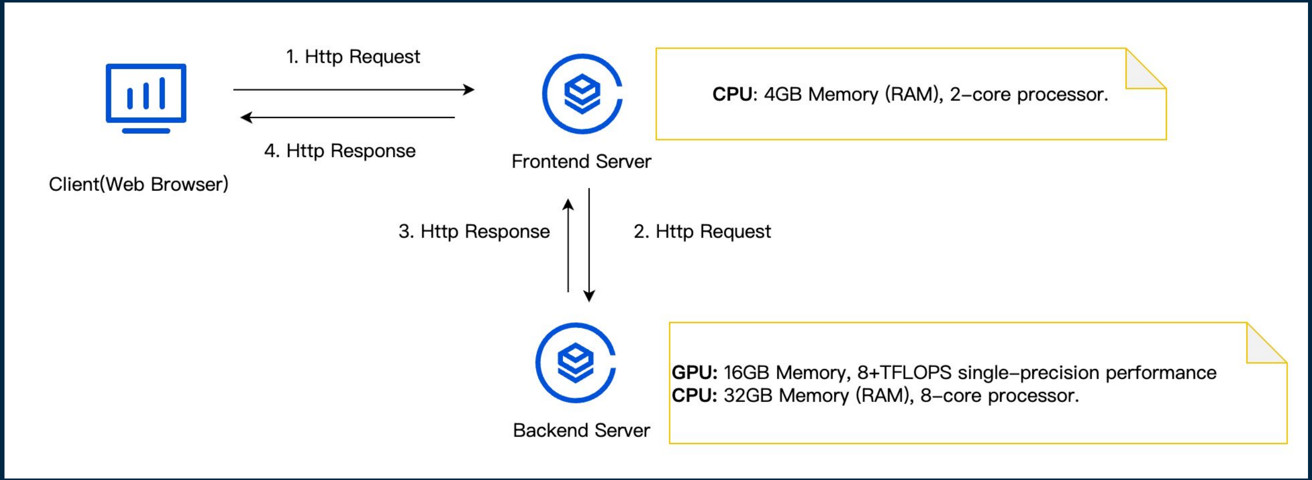
The Architecture Design Overview

Modular	Technology
Frontend	React, Tailwind CSS
Backend	FastAPI, Python, LangChain
Classifier	SVM & Latent Dirichlet Allocation (LDA)
Embedding	Sentence-Transformers (MiniLM)
Similarity Search	Cosine Similarity
LLM	LLaMA 3 (via Ollama)
Deployment	Cloud-Based Server (Microsoft Azure)

Technology Stack

3. System Design

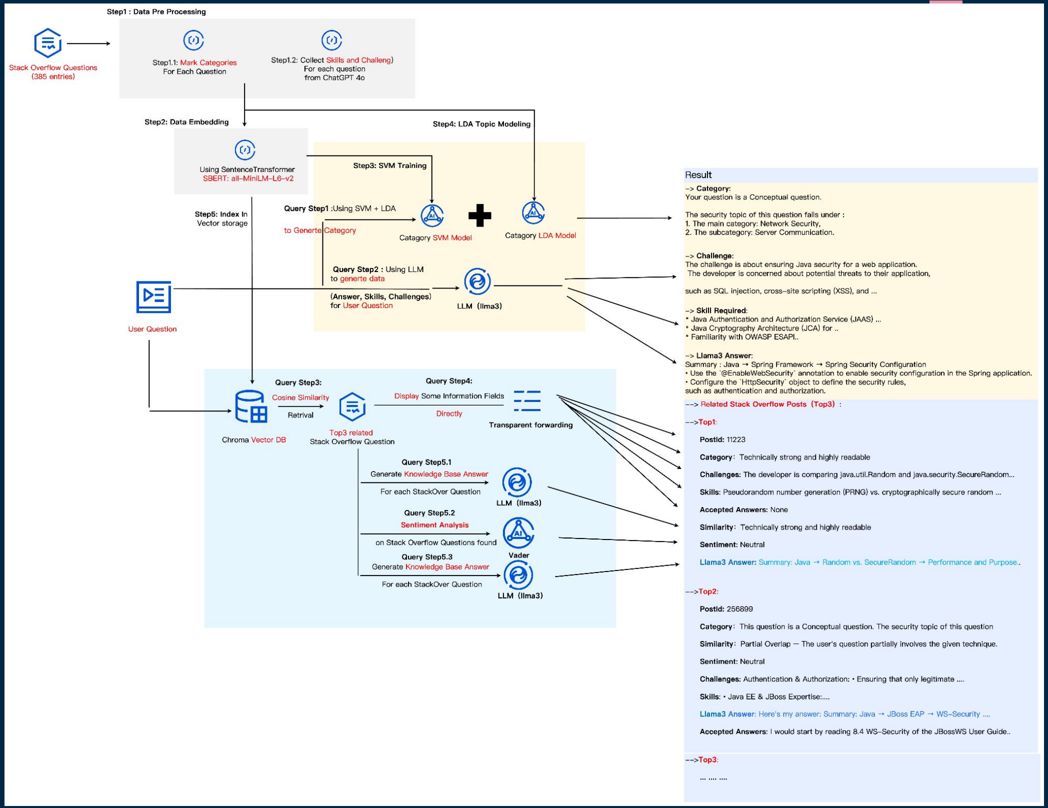
3.2 Deployment Overview



Deployment Architecture Overview

3. System Design

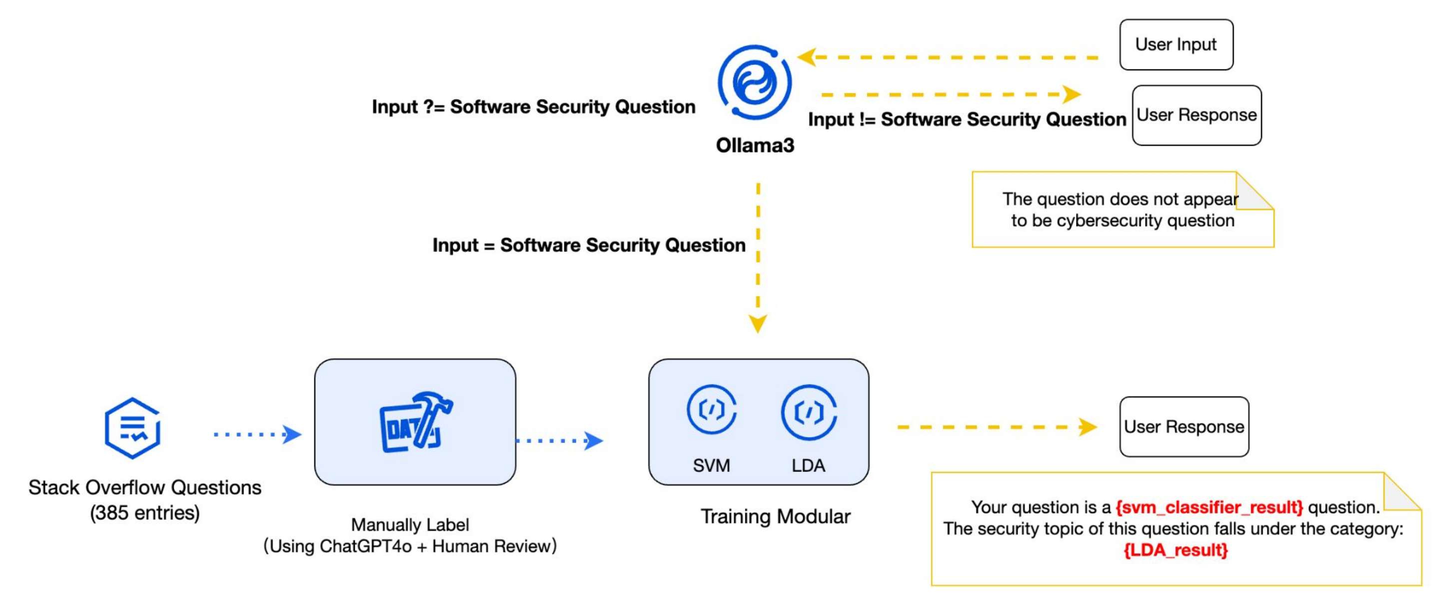
3.3 Data Workflow



Data Workflow of the whole Knowledge Base System

3. System Design

3.4 Classifier —– SVM & LDA



Stack Overflow Question Categorization Workflow

3. System Design

3.4 Classifier -- SVM & LDA

SVM Implementation Method

1. Label Original questions using ChatGPT-4o and human review
2. Encode text using all-MiniLM-L6-v2 embeddings
3. Calculate class weights for imbalance
4. Train SVM classifier
5. Save model & use it for prediction

LDA Implementation Method

1. Clean and tokenize raw questions
2. Build dictionary and corpus
3. Train multiple LDA models
4. Select the one with the best coherence score （0.44）
5. Assign each question to a topic with human-readable names (named by GPT-4o)

3. System Design

3.4 Classifier -- SVM & LDA

	precision	recall	f1-score	support
Conceptual	0.59	0.62	0.60	21
Debugging	0.83	0.87	0.85	60
How-to	0.64	0.56	0.60	32
accuracy			0.73	113
macro avg	0.69	0.68	0.68	113
weighted avg	0.73	0.73	0.73	113

Performance of the SVM classifier on the original dataset.

The model performs relatively well on the Debugging category. However, performance on Conceptual and How-to questions is lower, likely due to the semantic overlap between these two categories, which makes them harder to distinguish.

	precision	recall	f1-score	support
Conceptual	0.69	0.97	0.80	38
Debugging	1.00	1.00	1.00	30
How-to	0.94	0.47	0.62	32
accuracy			0.82	100
macro avg	0.87	0.81	0.81	100
weighted avg	0.86	0.82	0.81	100

Performance on the augmented dataset collected by ChatGPT-4o.

The classifier shows better generalization, especially on Conceptual and Debugging types, while How-to questions remain challenging.

3. System Design

3.5 Similarity Search Accuracy -- Evaluation

Choosing 3 embedding models and 3 Search Type to Compare

Model Name	Architecture	Languages	Semantic Accuracy	Inference Speed
all-MiniLM-L6-v2	MiniLM (6 layers)	English	Medium–High	Very Fast
all-mpnet-base-v2	MPNet (Base, ~110M)	English	Very High	Slower
paraphrase-multilingual-MiniLM-L12-v2	MiniLM (12 layers)	Multilingual (50+ langs)	Moderate (strong cross-lingual)	Fast

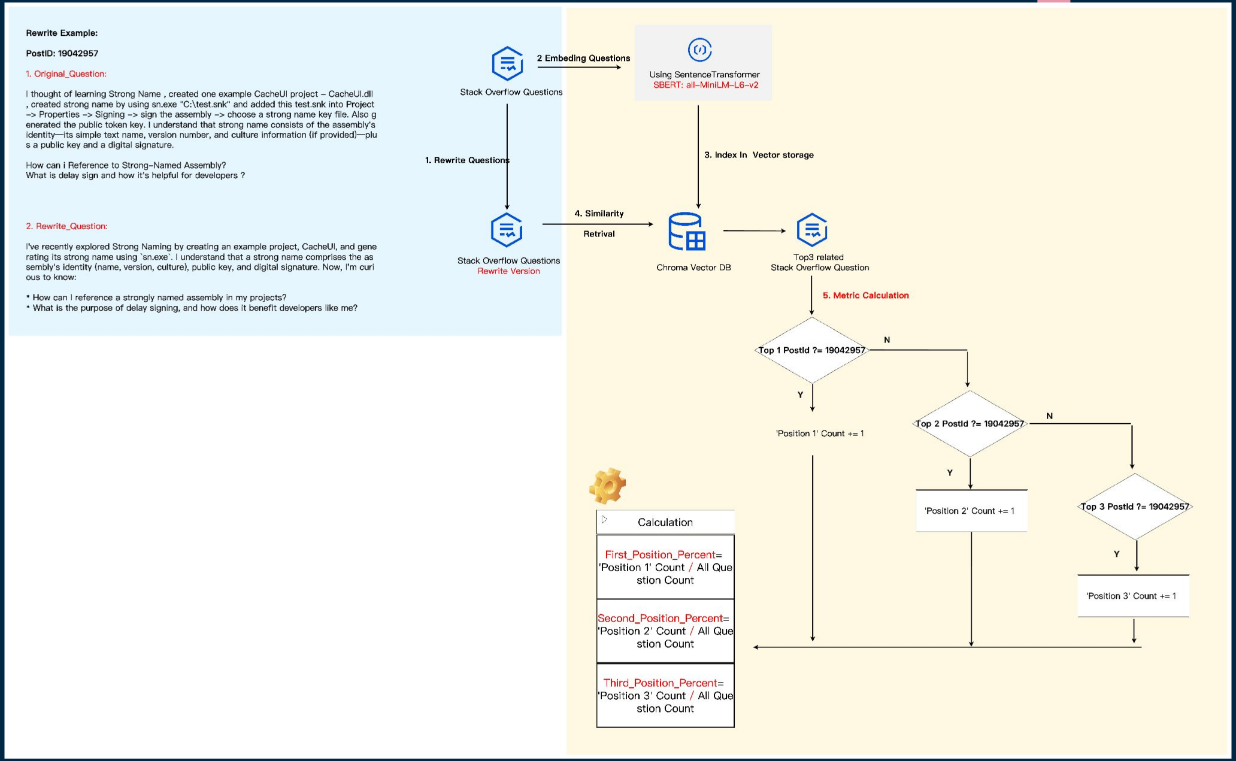
3 Embedding Models

Search Type	Core Principle
Similarity(cosine_similarity)	Retrieve documents with **highest cosine similarity** to query vector
Similarity_score_threshold	Similar to `similarity`, but adds a **minimum similarity threshold**
mmr(Maximal Marginal Relevance)	Balances similarity to query and **diversity among results**

3 Search Types

3. System Design

3.5 Similarity Search Accuracy —— Metrics



How to Define Metrics

3. System Design

3.5 Similarity Search Accuracy —- Results

- Search Type: Similarity(cosine_similarity)

	sentence-transformers/all-MiniLM-L6-v2	sentence-transformers/all-mpnet-base-v2	sentence-transformers/paraphrase-multilingual-MiniLM-L12-v2
first_position	97.86%	97.86%	97.86%
second_position	1.06%	1.06%	1.06%
third_position	0.0%	0.0%	0%
not_found	1.06%	1.06%	1.06%

- Search Type: Similarity_score_threshold

	sentence-transformers/all-MiniLM-L6-v2	sentence-transformers/all-mpnet-base-v2	sentence-transformers/paraphrase-multilingual-MiniLM-L12-v2
first_position	92.78%	92.78%	93.04%
second_position	0.0%	0.0%	0.0%
third_position	0.0%	0.26%	0.0%
not_found	7.21%	6.95%	6.95%

- Search Type: mmr(Maximal Marginal Relevance)

	sentence-transformers/all-MiniLM-L6-v2	sentence-transformers/all-mpnet-base-v2	sentence-transformers/paraphrase-multilingual-MiniLM-L12-v2
first_position	97.86%	97.86%	97.86%
second_position	0.53%	0.53%	0.53%
third_position	0.0%	0.0%	0.0%
not_found	1.6%	1.60%	1.60%

3. System Design

3.5 Similarity Search Model —— How to Present Similarity

Similarity	Definition
Exact Match	Almost identical to the accepted answer.
High Similarity	Closely matches the key points of the accepted answer.
Partial Match	Shares some common elements with the accepted answer.
Low Similarity	Minimal overlap with the accepted answer.
No Match	Completely different from the accepted answer.

Similarity Between Knowledge Base Answer and Accepted Answer

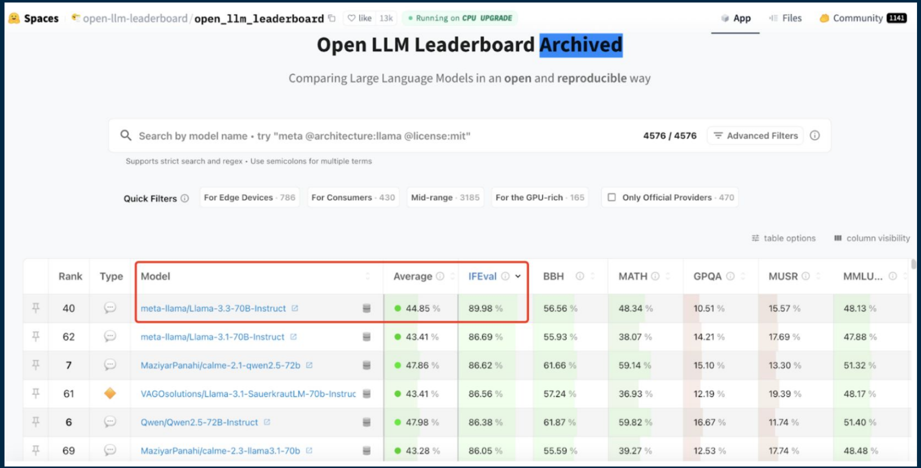
Similarity	Definition
Exact Match	Fully aligns with the given technique.
No Overlap	Unrelated to the given technique.
Partial Overlap	Partially involves the given technique.
Subset	Entirely within a smaller scope of the given technique.
Superset	Covers multiple techniques, including the given one.
Upstream /Downstream Relation	Uses a technology that builds on or underlies the given one.
Conceptual Intersection	On a broader concept that the given technique is part of.
Alternative Technology Context	Uses a different language/tech that serves a similar purpose.

Similarity Between User Input and Stack Overflow Question

3. System Design

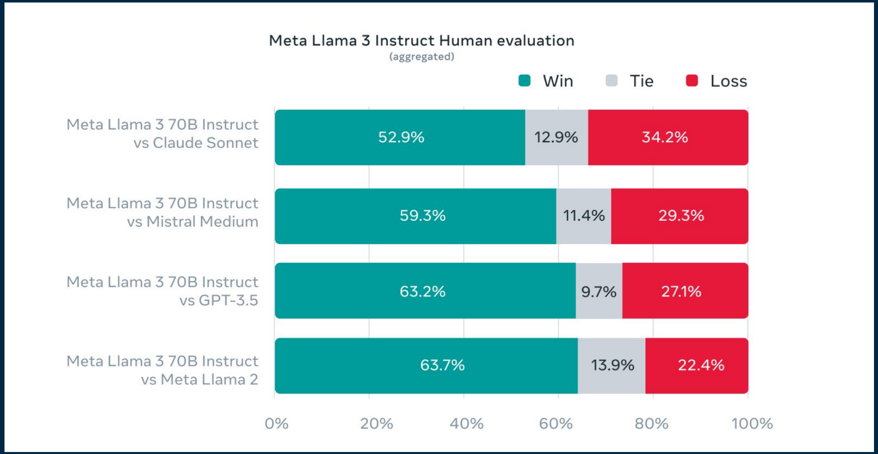
3.6 LLM Model

1. Llama3 Ranks 1 in Instruction-Following Evaluation (IFEval) Score



Rank	Type	Model	Average	IFEval	BBH	MATH	GPQA	MUSR	MMLU...
40		meta-llama/Llama-3.3-70B-Instruct	44.85 %	89.98 %	56.56 %	48.34 %	10.51 %	15.57 %	48.13 %
62		meta-llama/Llama-3.1-70B-Instruct	43.41 %	86.69 %	55.93 %	38.07 %	14.21 %	17.69 %	47.88 %
7		MaziyarPanahi/calme-2.1-qwen2.5-72b	47.86 %	86.62 %	61.66 %	59.14 %	15.10 %	13.30 %	51.32 %
61		VAGOsolutions/Llama-3.1-SauerkrautLM-70b-Instruc	43.41 %	86.56 %	57.24 %	36.93 %	12.19 %	19.39 %	48.17 %
6		Qwen/Qwen2.5-72B-Instruct	47.98 %	86.38 %	61.87 %	59.82 %	16.67 %	11.74 %	51.40 %
69		MaziyarPanahi/calme-2.3-llama3.1-70b	43.28 %	86.05 %	55.59 %	39.27 %	12.53 %	17.74 %	48.48 %

2. Llama3 Human evaluation



https://huggingface.co/spaces/open-llm-leaderboard/open_llm_leaderboard#/

https://ai.meta.com/blog/meta-llama-3/

3. System Design

3.7 Sentiment Analysis

Objective

To detect the emotional tone of the original user question

Method: VADER Sentiment Analyzer

- Based on a lexicon and rule-based sentiment analysis tool
- Provided by NLTK, pre-trained on social media and short texts
- We use compound score to classify into: Positive (> 0.05), Negative (< -0.05), Neutral (in between)
- Applied to the original user question to determine whether its sentiment is positive, neutral, or negative.

Conclusions & Reflections

04

4. Conclusions & Reflections

4.1 Conclusions

- Data Foundation and Function Coverage
- Effectiveness of technical Architecture
- Practical Application Value

4. Conclusions & Reflections

4.2 Reflections

Data Level	Data Scale and Diversity
	Label Consistency
Model and Algorithm Level	Limitations of Classification Models
	Room for Semantic Search Optimization
	LLM Configuration
System Design and User Experience Level	System Architecture
	Real-time Performance and Deployment Costs
Ethical and Security Level	Data Privacy Risks
Future Optimization Directions	Data Source Expansion (e.g., GitHub, real-time content integration)
	Model and System Upgradation
	Industry Perspective

Thank you for your attention

We are happy to take any questions